# Security Policy

## Supported versions

The `main` branch is the only supported version. Fixes are released there.

| Version | Supported |
|---|---|
| `main` | ✅ |
| older tags | ❌ |

## Reporting a vulnerability

Please **do not** open a public issue for security problems. Instead, report privately using GitHub's private vulnerability reporting (Security tab → Report a vulnerability) or contact the maintainer directly via @geff1778.

Please include:

- a description of the issue and its impact,
- steps to reproduce (a proof of concept if possible),
- affected version/commit,
- any suggested mitigation.

We aim to acknowledge reports within 72 hours and to provide a remediation timeline after triage. Please give us reasonable time to fix the issue before public disclosure.

## Security model & hardening notes

BrainStorm is a self-hosted application. A few design decisions matter for deployments:

- **Secrets** — `SECRET_KEY`, `ADMIN_SECRET_KEY` and `CHEAT_TESTER_CODE` have **no defaults**. In `ENV=production` the app refuses to start if they are missing or shorter than 16 chars. Keep them in `.env` (git-ignored) or your platform's secret store; never commit them.
- **Reverse proxy** — `X-Forwarded-For` is only trusted when `TRUST_PROXY=true`. Enable it only behind a trusted proxy, otherwise client IPs (and therefore rate limits) are spoofable.
- **Cookies** — set `SESSION_COOKIE_SECURE=true` when serving over HTTPS.
- **CORS** — set `CORS_ORIGINS` to explicit origins in production instead of `*`.
- **Rate limiting** — activation, auth and AI endpoints are rate limited in-process. For multi-worker deployments back this with Redis (see ROADMAP.md).
- **Cheat/admin mode** — privileged Socket.IO events require a session activated through `/api/cheat/activate` or `/api/admin/activate`; the keys are compared in constant time.
- **Password storage** — PBKDF2-HMAC-SHA256 with a per-password salt and 260 000 iterations; legacy hashes are transparently upgraded on next login.

If you find a gap in any of the above, please report it as described above.